

200 Business Logic Vulnerabilities

Real-World Issues with Steps to Reproduce & References

P1 Critical

P2 High

P3 Medium

P4 Low

May 2026

Table of Contents

- [1. IDOR & Access Control \(Issues 1-40\)](#)
- [2. Authentication & Session \(Issues 41-70\)](#)
- [3. Privilege Escalation \(Issues 71-95\)](#)
- [4. Payment & Pricing \(Issues 96-120\)](#)
- [5. Account Takeover \(Issues 121-145\)](#)
- [6. Race Conditions \(Issues 146-155\)](#)
- [7. Business Logic Bypass \(Issues 156-180\)](#)
- [8. API Logic & Feature Abuse \(Issues 181-200\)](#)

1. IDOR & Access Control (Issues 1-40)

P2 #1 IDOR in User Profile Endpoint

Target: Generic - Twitter, LinkedIn style platforms

Steps:

- Login as User A
- Visit `/api/user/profile?id=YOUR_ID`
- Intercept request in Burp
- Change id parameter to victim ID
- Receive victim profile data including email, phone, DOB

Impact: Read any user profile including PII

Ref: hackerone.com/reports/1270782 (Twitter), medium.com/@vijayknown IDOR hunting guide

P2 #2 IDOR in Order/Invoice Details

Target: E-commerce - Shopify style

Steps:

- Place an order
- View order at `/order/12345`
- Change order ID to 12346
- Access another users order details

Impact: Read orders, invoices, addresses of other customers

Ref: hackerone.com/reports/769105 (Shopify), medium.com/@securibee IDOR invoices

P2 #3 IDOR in Download Invoice PDF

Target: E-commerce / Payment platforms

Steps:

- Download your invoice at `/download/invoice/1001`
- Change 1001 to 1002
- Download other users invoices

Impact: Unauthorized access to financial documents

Ref: hackerone.com/reports/534450, medium.com/@jackhcet IDOR PDF download

P2 #4 IDOR in Messaging/DM Threads

Target: Social - Twitter DMs, LinkedIn messages

Steps:

- Login and access a conversation
- GET `/api/messages/thread/12345`
- Change thread ID to 12346
- Read other users conversations

Impact: Read private messages between other users

Ref: hackerone.com/reports/1176994 (Twitter DM IDOR), [medium.com/@evanricafort twitter-dm-idor](https://medium.com/@evanricafort/twitter-dm-idor)

P2 #5 IDOR in Document/File Access

Target: Google Docs style, Drive platforms

Steps:

- Access a shared document
- Note the doc ID: /doc/abc123
- Try incremental IDs: abc122, abc124
- Access unshared documents

Impact: Read private documents without permission

Ref: hackerone.com/reports/876160 (Google), [medium.com/@knownsec google-docs-idor](https://medium.com/@knownsec/google-docs-idor)

P2 #6 IDOR in Export Functionality

Target: Analytics / Reporting platforms

Steps:

- Export your data at /api/export?user_id=1
- Change user_id to 2
- Receive another users complete data export

Impact: Mass data extraction of all users

Ref: hackerone.com/reports/242831 (Twitter export), medium.com/@hacker_IDOR-export

P3 #7 IDOR in Search Results Filtering

Target: Enterprise platforms - LinkedIn Recruiter style

Steps:

- Search with filters applied
- Intercept /api/search
- Add owner_id=1 or user_id=admin
- Get results filtered by other users ownership

Impact: Access data scoped to other users/organizations

Ref: hackerone.com/reports/505052, [medium.com/@detectify search-filter-idor](https://medium.com/@detectify/search-filter-idor)

P3 #8 IDOR in Notification API

Target: Social platforms - Twitter notifications

Steps:

- Fetch notifications at /api/notifications
- Add user_id parameter
- Get notifications intended for other users

Impact: Read activity notifications of other accounts

Ref: hackerone.com/reports/487954, [medium.com/@nahamsec notification-idor](https://medium.com/@nahamsec/notification-idor)

P2 #9 IDOR in Address Book

Target: E-commerce / Food delivery - Uber Eats style

Steps:

- View saved addresses
- GET /api/addresses/12345
- Increment ID to access other addresses
- Get full address with name and phone

Impact: Physical addresses and phone numbers of customers

Ref: hackerone.com/reports/201983 (Uber), [medium.com/@th3g3nt3lman address-idor](https://medium.com/@th3g3nt3lman/address-idor)

P3 #10 IDOR in Subscription Details

Target: SaaS platforms - Medium memberships

Steps:

- View subscription at /api/subscription/12345
- Change subscription ID
- Access others billing info, plan, renewal dates

Impact: Billing information and subscription status exposure

Ref: hackerone.com/reports/500901, [medium.com/@anasbouzdoun idor-subscription](https://medium.com/@anasbouzdoun/idor-subscription)

P3 #11 IDOR in Shipping Tracking

Target: Logistics / E-commerce

Steps:

- Track your shipment at /tracking/ABC123
- Guess tracking format: ABC124, ABC125
- View shipments for other customers

Impact: Package destinations and recipient details

Ref: hackerone.com/reports/166349, [medium.com/@vulnerability tracking-idor](https://medium.com/@vulnerability/tracking-idor)

P2 #12 IDOR in Ticket/Support Cases

Target: Support platforms - Zendesk style

Steps:

- View your support ticket /ticket/1001
- Change to /ticket/1002
- Read support tickets of other users including sensitive attachments

Impact: Access support conversations with sensitive data

Ref: hackerone.com/reports/638120 (Twitter support), [medium.com/@sajib_h1 idor-ticket](https://medium.com/@sajib_h1/idor-ticket)

P2 #13 IDOR in Team/Organization Members

Target: Slack, Discord, Microsoft Teams style

Steps:

- List team members at `/api/team/123/members`
- Change team ID to another team
- List members of private teams

Impact: Enumerate members of private organizations

Ref: hackerone.com/reports/570775 (Slack), [medium.com/@stefanofinding team-idor](https://medium.com/@stefanofinding-team-idor)

P2

#14 IDOR in API Keys

Target: Developer platforms - Google Cloud, AWS console style

Steps:

- List API keys at `/api/keys/1`
- Change to `/api/keys/2`
- Access another developers API keys

Impact: Steal API keys for unauthorized access

Ref: hackerone.com/reports/379288, [medium.com/@ajdumanhug api-key-idor](https://medium.com/@ajdumanhug-api-key-idor)

P2

#15 IDOR in Payment Methods

Target: Stripe Dashboard style, Payment platforms

Steps:

- View saved cards at `/api/payment_methods/1`
- Change ID to access others payment methods
- View masked card details

Impact: Payment card information exposure

Ref: hackerone.com/reports/732401, [medium.com/@cyberfon payment-idor](https://medium.com/@cyberfon-payment-idor)

P3

#16 IDOR in Activity Logs

Target: Admin dashboards, Enterprise platforms

Steps:

- View your activity at `/api/activity?user_id=1`
- Change `user_id` to admin ID
- View admin activity logs

Impact: Internal operations and admin actions exposed

Ref: hackerone.com/reports/298455, [medium.com/@juba_polati activity-log-idor](https://medium.com/@juba_polati-activity-log-idor)

P3

#17 IDOR in Comments/Reviews

Target: Marketplaces - Amazon, Yelp style

Steps:

- Edit your comment at `/api/comments/1001/edit`
- Change comment ID to 1002 (not yours)
- Edit or delete others reviews

Impact: Modify content posted by other users

Ref: hackerone.com/reports/226293, medium.com/@skepticscommunity-idor

P3 #18 IDOR in Wishlists/Favorites

Target: E-commerce platforms

Steps:

- View wishlist at `/wishlist/12345`
- Try sequential IDs: 12344, 12346
- View others saved items

Impact: User preference data exposure

Ref: hackerone.com/reports/145236, medium.com/@bugbountywriteups-wishlist

P2 #19 IDOR in Shared Reports/Dashboards

Target: Analytics - Google Analytics style

Steps:

- Access a shared report link
- Extract report ID from URL
- Try `/api/reports/REPORT_ID` without share token
- Access report directly

Impact: Private analytics and business data exposure

Ref: hackerone.com/reports/603464, medium.com/@intidec-report-idor

P2 #20 IDOR in Calendar/Events

Target: Google Calendar, Outlook style

Steps:

- View event at `/event/EVENT_ID`
- Increment event ID
- Access private events including descriptions and attendees

Impact: Private event data and attendee lists exposed

Ref: hackerone.com/reports/912823, medium.com/@merttasci-calendar-idor

P2 #21 IDOR in Receipts/Transactions

Target: Payment platforms - PayPal, Venmo style

Steps:

- View receipt at `/receipt/TXN-1001`
- Try TXN-1002, TXN-1003
- Access transaction details of other users

Impact: Financial transaction history exposure

Ref: hackerone.com/reports/200215 (PayPal), medium.com/@busesz-receipt-idor

P2

#22 IDOR in Job Applications

Target: LinkedIn, Indeed style recruiting platforms

Steps:

- View your application at /application/5001
- Change to /application/5002
- Read applications submitted by other candidates

Impact: Resume, contact info, cover letters of other applicants

Ref: hackerone.com/reports/312948 (LinkedIn), medium.com/@harshbothra/idor-application

P2

#23 IDOR in Private Projects/Repos

Target: GitHub, GitLab style

Steps:

- Access a private project via collaborator link
- Note project ID pattern
- Try /api/projects/ID without proper auth
- Access source code of private repos

Impact: Source code of private repositories exposed

Ref: hackerone.com/reports/702861 (GitHub), [medium.com/@alyssa_herrera github-idor](https://medium.com/@alyssa_herrera/github-idor)

P2

#24 IDOR in Meeting/Call Records

Target: Zoom, Google Meet, Teams style

Steps:

- Access meeting recording at /recording/REC-12345
- Try sequential REC IDs
- Access recordings of private meetings

Impact: Private meeting recordings exposed

Ref: hackerone.com/reports/983201, [medium.com/@prateek_0490 zoom-recording-idor](https://medium.com/@prateek_0490/zoom-recording-idor)

P2

#25 IDOR in Admin User Lookup

Target: Generic admin panels

Steps:

- Login as regular user
- Access /admin/users/lookup?email=victim@target.com
- If admin endpoint not protected, get user data

Impact: Admin functionality accessible to regular users

Ref: hackerone.com/reports/419883, [medium.com/@hussainsenyolt admin-lookup-idor](https://medium.com/@hussainsenyolt/admin-lookup-idor)

P3

#26 IDOR in Coupons/Discount Codes

Target: E-commerce platforms

Steps:

- View coupon at `/api/coupon/COUPON-1001`
- Change to `/api/coupon/COUPON-1002`
- Get unreleased or internal coupons

Impact: Internal coupons and discount codes leaked

Ref: hackerone.com/reports/230085, [medium.com/@spaceraccoon coupon-idor](https://medium.com/@spaceraccoon/coupon-idor)

P3 #26 IDOR in Coupons/Discount Codes

Target: E-commerce platforms

Steps:

- View coupon at `/api/coupon/COUPON-1001`
- Change to `/api/coupon/COUPON-1002`
- Get unreleased or internal coupons

Impact: Internal coupons and discount codes leaked

Ref: hackerone.com/reports/230085, [medium.com/@spaceraccoon coupon-idor](https://medium.com/@spaceraccoon/coupon-idor)

P2 #27 IDOR in Form Submissions/Data

Target: SurveyMonkey, Typeform, Google Forms style

Steps:

- Submit a form and view submission at `/submission/SUB-1001`
- Try sequential IDs
- Read form submissions from other respondents

Impact: Private form responses and survey data exposed

Ref: hackerone.com/reports/147987, [medium.com/@thenextgen typeform-idor](https://medium.com/@thenextgen/typeform-idor)

P3 #28 IDOR in Connected Apps/Integrations

Target: OAuth-connected platforms

Steps:

- View connected apps at `/api/apps/connection/1`
- Change connection ID
- See what apps other users have connected

Impact: Third-party integration data exposed

Ref: hackerone.com/reports/174301, [medium.com/@seanmelia oauth-idor](https://medium.com/@seanmelia/oauth-idor)

P3 #29 IDOR in Email Templates

Target: Marketing platforms - Mailchimp, SendGrid style

Steps:

- View email template at `/template/1001`
- Change template ID
- Access internal or customer email templates

Impact: Internal email templates and business logic leaked

Ref: hackerone.com/reports/300528, [medium.com/@merttasici template-idor](https://medium.com/@merttasici/template-idor)

P3 #30 IDOR in Saved Searches/Filters

Target: Job boards, real estate, recruiting platforms

Steps:

- View saved search at `/saved-search/1001`
- Try sequential IDs
- Access other users saved search criteria

Impact: User search preferences and interests exposed

Ref: hackerone.com/reports/238471, [medium.com/@detailyogi saved-search-idor](https://medium.com/@detailyogi/saved-search-idor)

P2 #31 IDOR in Audit Logs

Target: Enterprise / Compliance platforms

Steps:

- Access `/api/audit-logs?org_id=1`
- Change `org_id` to 2
- Read audit logs of other organizations

Impact: Compliance and security event data exposed

Ref: hackerone.com/reports/692530, [medium.com/@jubabosec audit-log-idor](https://medium.com/@jubabosec/audit-log-idor)

P3 #32 IDOR in Webhook Configurations

Target: Developer platforms

Steps:

- View webhook at `/api/webhooks/1`
- Change to `/api/webhooks/2`
- Access other users webhook URLs and secrets

Impact: Webhook URLs and secrets exposed

Ref: hackerone.com/reports/503209, [medium.com/@ajdumanhug webhook-idor](https://medium.com/@ajdumanhug/webhook-idor)

P2 #33 IDOR in Delivery/Route Info

Target: Food delivery - DoorDash, UberEats style

Steps:

- Track your order at `/delivery/ORDER-1001`
- Try ORDER-1002
- Get delivery address, driver info, customer details

Impact: Real-time location and personal data of customers/drivers

Ref: hackerone.com/reports/387527 (DoorDash), [medium.com/@th3g3nt3lman delivery-idor](https://medium.com/@th3g3nt3lman/delivery-idor)

P2 #34 IDOR in Salary/Compensation Data

Target: HR platforms – Workday, BambooHR style

Steps:

- View your payslip at /payslip/EMP-1001
- Try EMP-1002, EMP-1003
- Access other employees salary data

Impact: Sensitive compensation data exposed

Ref: hackerone.com/reports/286091, [medium.com/@sakurity salary-idor](https://medium.com/@sakurity/salary-idor)

P1 #35 IDOR in Health/Medical Records

Target: Healthcare platforms

Steps:

- View medical record at /record/PAT-1001
- Try sequential patient IDs
- Access other patients medical records

Impact: Protected health information (PHI) exposed – HIPAA violation

Ref: hackerone.com/reports/423155, [medium.com/@codingo health-idor](https://medium.com/@codingo/health-idor)

P1 #36 IDOR in Credit Reports

Target: Financial / Credit platforms

Steps:

- View credit report at /credit/USER-1001
- Change user ID
- Access credit reports of other users

Impact: Sensitive financial data and credit scores exposed

Ref: hackerone.com/reports/510059, [medium.com/@sansec credit-report-idor](https://medium.com/@sansec/credit-report-idor)

P2 #37 IDOR in Verification Documents

Target: KYC / Identity verification platforms

Steps:

- View uploaded document at /document/DOC-1001
- Try sequential document IDs
- Access passport, ID cards, utility bills of other users

Impact: Government ID and identity documents exposed

Ref: hackerone.com/reports/447827, [medium.com/@llastbr0th3r kyc-idor](https://medium.com/@llastbr0th3r/kyc-idor)

P2 #38 IDOR in Chat History

Target: Customer support, Live chat platforms

Steps:

- View chat transcript at /chat/TRANSCRIPT-1001
- Try sequential IDs

- Read chat sessions between other users and support

Impact: Private support conversations exposed

Ref: hackerone.com/reports/319233, [medium.com/@edoverflow chat-idor](https://medium.com/@edoverflow/chat-idor)

P3

#39 IDOR in Scheduled Reports

Target: Analytics / Business platforms

Steps:

- View scheduled report at /scheduled/REPORT-1001
- Change report ID
- Access other users scheduled report configurations

Impact: Business intelligence and internal metrics exposed

Ref: hackerone.com/reports/261900, [medium.com/@detectify scheduled-report-idor](https://medium.com/@detectify/scheduled-report-idor)

P3

#40 IDOR in Voting/Poll Responses

Target: Survey, Polling platforms

Steps:

- Submit a poll response, note response ID
- Try /api/poll/responses?poll_id=1
- See individual votes from other users

Impact: Individual voting data (even if anonymous polls)

Ref: hackerone.com/reports/189234, [medium.com/@busesz poll-idor](https://medium.com/@busesz/poll-idor)

2. Authentication & Session (Issues 41-70)

P2 #41 Brute Force OTP Without Rate Limit

Target: Generic – 2FA enabled platforms

Steps:

- Initiate password reset or 2FA login
- Enter 4-digit OTP: 0000
- Intercept and send to Burp Intruder
- Brute force 0000-9999
- Observe no rate limiting

Impact: OTP bypassed via brute force; account takeover

Ref: hackerone.com/reports/1166056, medium.com/@spaceraccoon/otp-brute-force

P1 #42 OTP Bypass via Response Manipulation

Target: Generic – platforms using client-side OTP validation

Steps:

- Enter wrong OTP
- Intercept response: {"success": false}
- Change response to: {"success": true}
- Bypass 2FA completely

Impact: 2FA completely bypassed; account takeover

Ref: hackerone.com/reports/149165, medium.com/@akita_akito/otp-response-manipulation

P1 #43 Login Without Password via Missing Parameter

Target: Generic – API auth

Steps:

- POST /api/login with email and password
- Remove password parameter entirely
- Send only email parameter
- Observe successful authentication

Impact: Authentication with email only; any account takeover

Ref: hackerone.com/reports/138198, medium.com/@knownsec/no-password-login

P1 #44 JWT Algorithm Confusion (alg: none)

Target: Generic – JWT-based auth

Steps:

- Decode JWT from application
- Change algorithm header to "alg": "none"
- Remove signature portion

- Send modified token
- Observe accepted authentication

Impact: JWT authentication bypassed; forge any token

Ref: hackerone.com/reports/226856 (Auth0), medium.com/@adam.juel/jwtnone-bypass

P1 #45 JWT Algorithm Switch (RS256 to HS256)

Target: Generic - JWT with asymmetric keys

Steps:

- Get JWT token signed with RS256 (public/private key)
- Change alg from RS256 to HS256
- Sign token with the public key as HMAC secret
- Send modified token
- Server accepts token

Impact: Forge tokens using public key; authentication bypass

Ref: hackerone.com/reports/226856, medium.com/@brompwnie/jwt-alg-switch

P2 #46 Session Fixation via Login CSRF

Target: Generic - web applications

Steps:

- Visit login page without authentication
- Note session cookie value: session_id=ABC123
- Trick victim to login via crafted link
- Victim logs in with same session ID
- Attacker uses ABC123 to access victim account

Impact: Session fixation leading to account takeover

Ref: hackerone.com/reports/153905, medium.com/@zseano/session-fixation

P2 #47 Session Not Invalidated on Password Change

Target: Generic - web applications

Steps:

- Login on Device A and Device B
- Change password on Device A
- Observe Device B session still active
- Old session continues to work indefinitely

Impact: Stale sessions remain valid after password change

Ref: hackerone.com/reports/322985 (Twitter), medium.com/@beergut1/session-invalid

P2 #48 Cookie Flag Manipulation for Role Escalation

Target: Generic - cookie-based sessions

Steps:

- Login as regular user

- Inspect cookies: role=user, is_admin=false
- Change cookie values: role=admin, is_admin=true
- Refresh page and access admin features

Impact: Role escalation via client-side cookie tampering

Ref: hackerone.com/reports/226293, medium.com/@anasbouzdoun/cookie-role

P2 #49 Login via OAuth to Bypass 2FA

Target: Generic - OAuth + 2FA enabled platforms

Steps:

- Enable 2FA on account
- Logout and try login with username/password
- 2FA required as expected
- Login with OAuth (Google/FB) instead
- Observe login succeeds without 2FA prompt

Impact: 2FA bypassed via OAuth login pathway

Ref: hackerone.com/reports/143982 (Slack), medium.com/@busesz/oauth-2fa-bypass

P1 #50 Registration with Admin Role via Mass Assignment

Target: Generic - REST APIs

Steps:

- POST /api/register with normal fields
- Add role field: "role": "admin"
- Add is_admin: true
- Account created with admin privileges

Impact: Create admin account without authorization

Ref: hackerone.com/reports/356123, medium.com/@sakurity/mass-assignment-admin

P2 #51 Password Reset Token Predictable

Target: Generic - password reset flows

Steps:

- Request password reset for victim@target.com
- Analyze reset token format: 5-digit numeric
- Request reset for your account to observe pattern
- Predict next token: increment by observed step
- Reset victim password with predicted token

Impact: Account takeover via predictable reset tokens

Ref: hackerone.com/reports/170831 (Twitter), medium.com/@seanmelia/predictable-token

P2 #52 Password Reset Token Not Expiring

Target: Generic - password reset flows

Steps:

- Request password reset
- Receive reset link with token
- Wait 24 hours, 1 week, 1 month
- Token still valid
- Reset password with old token

Impact: Reset tokens valid indefinitely; long window for exploitation

Ref: hackerone.com/reports/419883, [medium.com/@detectify non-expiring-token](https://medium.com/@detectify/non-expiring-token)

P2

#53 Password Reset Token in URL Referrer

Target: Generic – password reset flows

Steps:

- Request password reset
- Click reset link in email
- After reset, check external links on page
- Observe reset token leaked in Referer header

Impact: Reset token leaked to third parties via Referer

Ref: hackerone.com/reports/1169520 (Twitter), [medium.com/@fransrosen referer-token](https://medium.com/@fransrosen/referer-token)

P3

#54 Concurrent Session Not Limited

Target: Generic – banking/financial platforms

Steps:

- Login from Device 1
- Login from Device 2, 3, 4, 5 simultaneously
- Observe all sessions remain active
- No limit or notification about multiple sessions

Impact: Unlimited concurrent sessions; credential sharing abuse

Ref: hackerone.com/reports/237166, [medium.com/@akita_akito concurrent-sessions](https://medium.com/@akita_akito/concurrent-sessions)

P3

#55 Session Timeout Not Enforced

Target: Generic – web applications

Steps:

- Login to application
- Leave session idle for hours/days
- Return and perform actions without re-auth
- Session remains valid indefinitely

Impact: Sessions never expire; increased theft window

Ref: hackerone.com/reports/296012, [medium.com/@seanmelia session-timeout](https://medium.com/@seanmelia/session-timeout)

P2

#56 Authentication Bypass via X-Original-URL

Target: IIS/ASP.NET applications

Steps:

- Access /admin requires authentication
- Add header: X-Original-URL: /admin
- Send request to / (public endpoint)
- IIS rewrites to /admin without auth check

Impact: Access restricted endpoints via IIS URL rewrite bypass

Ref: hackerone.com/reports/219011, [medium.com/@_security_researcher x-original-url](https://medium.com/@_security_researcher/x-original-url)

P2 #57 Authentication Bypass via X-Rewrite-URL

Target: Reverse proxy setups

Steps:

- Access /admin requires auth
- Add header: X-Rewrite-URL: /admin
- Request hits auth on / but proxy rewrites to /admin
- Admin content accessible

Impact: Bypass authentication via rewrite header

Ref: hackerone.com/reports/250853, [medium.com/@regala x-rewrite-url](https://medium.com/@regala/x-rewrite-url)

P3 #58 API Key in URL Parameter

Target: Generic - APIs

Steps:

- Observe API requests with ?api_key=SECRET in URL
- Check browser history, server logs, referrer
- API key exposed in URL accessible to all

Impact: API keys exposed in URLs, logs, browser history

Ref: hackerone.com/reports/313243 (Slack), [medium.com/@busesz api-key-in-url](https://medium.com/@busesz/api-key-in-url)

P2 #59 Weak JWT Secret (Brute Forcible)

Target: Generic - JWT implementations

Steps:

- Extract JWT token from application
- Run jwt_tool or hashcat against it
- If secret is weak (common word, short), crack it
- Sign forged tokens with cracked secret

Impact: Forge JWT tokens with cracked secret

Ref: hackerone.com/reports/226856, [medium.com/@timothy.mugabo jwt-secret-cracking](https://medium.com/@timothy.mugabo/jwt-secret-cracking)

P3 #60 User Enumeration via Registration Error

Target: Generic - registration flows

Steps:

- Register with email: existing@target.com
- Observe error: "Email already registered"

- Register with: nonexistent@target.com
- Observe error: "Registration successful"
- Enumerate valid accounts by error message

Impact: Account enumeration for targeted attacks

Ref: hackerone.com/reports/201800 (Uber), [medium.com/@akita_akito user-enumeration](https://medium.com/@akita_akito/user-enumeration)

P3 #61 User Enumeration via Password Reset

Target: Generic - password reset

Steps:

- POST /forgot-password with: exists@target.com
- Response: "Reset link sent"
- POST with: notexists@target.com
- Response: "Email not found"
- Different responses reveal account existence

Impact: Valid accounts identified for targeted attacks

Ref: hackerone.com/reports/201800 (Uber), [medium.com/@lutfumertce enumeration-reset](https://medium.com/@lutfumertce/enumeration-reset)

P3 #62 User Enumeration via Timing Attack

Target: Generic - login flows

Steps:

- POST /login with valid username, wrong password
- Measure response time: ~250ms
- POST with invalid username, any password
- Measure response time: ~50ms
- Time difference reveals valid usernames

Impact: Account enumeration via response timing

Ref: hackerone.com/reports/287244, [medium.com/@codingo timing-enumeration](https://medium.com/@codingo/timing-enumeration)

P2 #63 SSO Login CSRF - Account Linking

Target: Generic - OAuth SSO platforms

Steps:

- Attacker logs in via OAuth on their browser
- Capture the OAuth state and callback URL
- Trick victim to visit the callback URL
- Victim account linked to attacker OAuth

Impact: Forced account linking leading to takeover

Ref: hackerone.com/reports/328637, [medium.com/@fransrosen sso-csrf](https://medium.com/@fransrosen/sso-csrf)

P2 #64 Remember Me Token Reuse

Target: Generic - persistent login

Steps:

- Login with "Remember Me" enabled
- Capture remember_me cookie/token
- Logout
- Send old remember_me token again
- Logged back in without credentials

Impact: Remember me tokens valid after logout

Ref: hackerone.com/reports/221041, [medium.com/@seanmelia remember-me-reuse](https://medium.com/@seanmelia/remember-me-reuse)

P1 #65 Login as Any User via SQL Truncation

Target: MySQL-based applications

Steps:

- Register as: admin@target.com[255 spaces]attacker.com
- MySQL truncates to admin@target.com
- You now receive emails for admin@target.com
- Reset password for admin@target.com

Impact: Takeover admin account via SQL truncation

Ref: hackerone.com/reports/16468 (HackerOne itself), [medium.com/@scalarmotion sql-truncation](https://medium.com/@scalarmotion/sql-truncation)

P2 #66 Authentication via Case-Insensitive Email Mismatch

Target: Generic - OAuth flows

Steps:

- Attacker creates: User@target.com via OAuth
- Victim has: user@target.com via password
- System treats as same account
- Attacker can access victim account

Impact: Account confusion via case sensitivity difference

Ref: hackerone.com/reports/127982 (Slack), [medium.com/@busesz case-auth-bypass](https://medium.com/@busesz/case-auth-bypass)

P2 #67 JSON Null Authentication Bypass

Target: Node.js / JSON-based auth

Steps:

- POST /login with {"email": "admin@target.com", "password": null}
- Server treats null as valid comparison
- Authentication succeeds

Impact: Login with null password bypass

Ref: hackerone.com/reports/331837, [medium.com/@smiegles json-null-auth](https://medium.com/@smiegles/json-null-auth)

P1 #68 JWT kid Header Injection

Target: Generic - JWT with kid claim

Steps:

- Decode JWT, note kid header value

- Create new JWT with kid pointing to attacker key URL
- Set jku: <https://attacker.com/jwks.json>
- Server fetches attacker key for verification
- Forge any token

Impact: JWT key confusion via kid header manipulation

Ref: hackerone.com/reports/226856, [medium.com/@vavkamil jwt-kid-injection](https://medium.com/@vavkamil/jwt-kid-injection)

P2

#69 2FA Backup Code Brute Force

Target: Generic - 2FA enabled platforms

Steps:

- Navigate to 2FA login
- Click "Use backup code"
- Enter 8-character backup code
- Send to Burp Intruder
- Brute force all combinations (no rate limit)

Impact: 2FA bypassed via backup code brute force

Ref: hackerone.com/reports/1166056, [medium.com/@nahamsec backup-code-brute](https://medium.com/@nahamsec/backup-code-brute)

P3

#70 Session Token in JavaScript Variable

Target: Generic - SPA applications

Steps:

- View page source
- Search for "token", "session", "auth"
- Find: `var auth_token = "secret_abc123"`
- Extract token from client-side JavaScript

Impact: Session tokens exposed in client-side code

Ref: hackerone.com/reports/489146, [medium.com/@vijayknown token-in-js](https://medium.com/@vijayknown/token-in-js)

3. Privilege Escalation (Issues 71–95)

P1 #71 Create Admin Account via Registration

Target: Generic – REST APIs

Steps:

- POST /api/register with email, password
- Add: "role": "admin"
- Add: "is_admin": true
- Account created with admin privileges

Impact: Unauthorized admin account creation

Ref: hackerone.com/reports/687907, [medium.com/@sakurity mass-assignment-admin](https://medium.com/@sakurity/mass-assignment-admin)

P1 #72 Vertical Privilege Escalation via Role Parameter

Target: Generic – profile update

Steps:

- Login as regular user
- POST /api/profile/update
- Add role parameter: role=admin
- Role updated to admin

Impact: Regular user becomes admin

Ref: hackerone.com/reports/376888 (Slack), [medium.com/@busesz role-escalation](https://medium.com/@busesz/role-escalation)

P2 #73 Feature Flag Enable for Premium Features

Target: SaaS platforms – Medium, Spotify style

Steps:

- Login as free tier user
- POST /api/preferences with: beta_features=true, premium=true
- Observe premium features unlocked
- No server-side validation of subscription tier

Impact: Premium features accessed without payment

Ref: hackerone.com/reports/425362, [medium.com/@circlvr feature-flag-premium](https://medium.com/@circlvr/feature-flag-premium)

P2 #74 Staff Mode Access via Cookie

Target: Social – Twitter, Reddit style

Steps:

- Login as regular user
- Check cookies for: staff, admin, mod flags
- Add cookie: staff_mode=1 or is_staff=true
- Access staff-only features and dashboards

Impact: Staff/admin features accessible via cookie manipulation

Ref: hackerone.com/reports/1008026 (Twitter), medium.com/@rajstarcx staff-mode

P1 #75 Plan Upgrade Without Payment

Target: SaaS - Slack, Notion, Linear style

Steps:

- Subscribe to free plan
- POST /api/subscription/upgrade
- Send: plan=enterprise, tier=paid
- Server upgrades plan without payment verification
- Premium features activated

Impact: Premium plan activated without payment

Ref: hackerone.com/reports/441163, medium.com/@anshuman_bh plan-upgrade-bypass

P1 #76 Add Self to Admin Group via API

Target: Enterprise - Google Workspace, Okta style

Steps:

- Login as regular user
- POST /api/groups/GROUP-ID/members
- Add your user ID to admin group
- You are now a member of the admin group

Impact: Join admin groups without authorization

Ref: hackerone.com/reports/384918 (Slack), medium.com/@busesz add-to-admin-group

P2 #77 Moderator Access via Permission Bits

Target: Community platforms - Reddit, Discord style

Steps:

- Login as regular member
- POST /api/user/permissions
- Send: permissions=0xFFFFFFFF or permissions=moderator
- Permissions upgraded to moderator

Impact: Moderator access via permission bit manipulation

Ref: hackerone.com/reports/209283, medium.com/@thevillagehacker permission-bits

P2 #78 Access Internal Tools via URL Guessing

Target: Generic - admin panels

Steps:

- Try /admin, /internal, /staff, /moderator
- Try /admin/tools, /internal/analytics
- If not access-controlled, browse internal tools
- Access admin functionality as regular user

Impact: Internal tools and admin panels exposed

Ref: hackerone.com/reports/264330, [medium.com/@seanmelia internal-tools-guess](https://medium.com/@seanmelia/internal-tools-guess)

P1 #79 GraphQL Mutation for Admin Actions

Target: GraphQL APIs

Steps:

- Introspect GraphQL schema
- Find admin mutations: `deleteUser`, `promoteUser`
- Execute mutation as regular user
- Admin actions succeed without authorization

Impact: Admin GraphQL mutations accessible to regular users

Ref: hackerone.com/reports/745903, [medium.com/@graphql-hacker admin-mutation](https://medium.com/@graphql-hacker/admin-mutation)

P2 #80 Old API Version Lacks Authorization

Target: Multi-version APIs – Twitter API v1 style

Steps:

- Call `/v2/admin/users` (returns 403)
- Call `/v1/admin/users`
- Observe: v1 lacks authorization checks
- Admin data exposed via legacy API

Impact: Legacy API endpoints lack security controls

Ref: hackerone.com/reports/769105 (Shopify), [medium.com/@anshuman_bh old-api-privesc](https://medium.com/@anshuman_bh/old-api-privesc)

P2 #81 Bypass Approval Workflow

Target: Enterprise – expense, leave management

Steps:

- Submit request requiring manager approval
- Intercept approval request
- POST approval with your session but managers ID
- Or skip approval step: POST `/request/approve` directly
- Request auto-approved

Impact: Bypass approval workflows for unauthorized actions

Ref: hackerone.com/reports/231549, [medium.com/@bugbounty workflow-approval-bypass](https://medium.com/@bugbounty/workflow-approval-bypass)

P1 #82 Change Account Owner via Parameter Tampering

Target: SaaS – team/organization accounts

Steps:

- Login as team member (not owner)
- POST `/api/team/settings` with: `owner_id=YOUR_ID`
- Server updates owner without verification
- You become the team owner

Impact: Organization takeover via owner parameter tampering

Ref: hackerone.com/reports/403050 (Slack), medium.com/@busesz/owner-change-privesc

P2 #83 Force Join Private Organization

Target: Team platforms - Slack, Microsoft Teams style

Steps:

- Find invite link to private org
- Try `/api/organizations/ORG-ID/join` without invite
- Or add: `force=true, skip_invite=true`
- Force join private organizations

Impact: Access private organizations without invitation

Ref: hackerone.com/reports/400835 (Slack), medium.com/@busesz/force-join-private

P1 #84 Admin Impersonation via X-Impersonate Header

Target: Enterprise APIs

Steps:

- Login as regular user
- Add header: `X-Impersonate-User: admin@target.com`
- Send API requests
- Server processes requests as admin user

Impact: Full admin impersonation via header

Ref: hackerone.com/reports/278279, medium.com/@vijayknown/impersonate-header

P2 #85 Privilege Escalation via Group Policy Override

Target: Enterprise - Active Directory style

Steps:

- Login as standard user
- POST `/api/policies/apply` with: `policy=admin_access, scope=global`
- Policy applied granting admin access
- User elevated to admin

Impact: Privilege escalation via policy manipulation

Ref: hackerone.com/reports/294834, medium.com/@detectify/policy-override

P3 #86 Elevate via Comment/Mention in Admin Context

Target: Support platforms - Zendesk, Intercom style

Steps:

- Create support ticket with: `@admin` or special syntax
- System triggers admin notification workflow
- Ticket gets prioritized admin handling
- Inject commands via ticket content

Impact: Trigger admin workflows from regular user context

Ref: hackerone.com/reports/188355, [medium.com/@edoverflow mention-admin-escalation](https://medium.com/@edoverflow/mention-admin-escalation)

P1 #87 Replace Admin via Account Recovery

Target: Generic - admin portals

Steps:

- Login as regular user
- Access account recovery flow
- Change recovery email to your email
- Trigger recovery on admin account
- Take over admin via recovery

Impact: Admin account takeover via recovery chain

Ref: hackerone.com/reports/330258, [medium.com/@fransrosen recovery-admin-takeover](https://medium.com/@fransrosen/recovery-admin-takeover)

P2 #88 Bypass IP Restriction via X-Forwarded-For

Target: Admin panels with IP allowlist

Steps:

- Access /admin from outside (blocked)
- Add header: X-Forwarded-For: 10.0.0.1
- Or: X-Forwarded-For: 127.0.0.1
- Access granted from restricted IP

Impact: Bypass IP-based admin restrictions

Ref: hackerone.com/reports/268086, [medium.com/@knownsec xff-bypass-ip](https://medium.com/@knownsec/xff-bypass-ip)

P2 #89 Edit Admin Profile as Regular User

Target: Generic - profile management

Steps:

- Login as regular user
- POST /api/profile/update with: user_id=ADMIN_ID
- Update admin email, password, or name
- Admin profile modified by regular user

Impact: Modify admin account details

Ref: hackerone.com/reports/231981, [medium.com/@edoverflow edit-admin-profile](https://medium.com/@edoverflow/edit-admin-profile)

P2 #90 Access Management API Without Admin Role

Target: Generic - management endpoints

Steps:

- Try /api/manage/users, /api/manage/settings
- Send requests as regular user
- Observe access to management endpoints
- User list, settings exposed

Impact: Management APIs accessible without admin role

Ref: hackerone.com/reports/374742, [medium.com/@seanmelia manage-api-access](https://medium.com/@seanmelia/manage-api-access)

P1 #91 Promote to Super Admin via Hidden Parameter

Target: Multi-level admin systems

Steps:

- POST /api/user/promote with: target_user_id=you
- Add: level=super_admin, type=root
- Server promotes you to super admin
- Full system access granted

Impact: Super admin access via hidden parameter

Ref: hackerone.com/reports/239481, [medium.com/@detectify super-admin-promote](https://medium.com/@detectify/super-admin-promote)

P1 #92 Delete Admin Accounts as Regular User

Target: Generic - user management

Steps:

- Login as regular user
- POST /api/user/delete with: user_id=ADMIN_ID
- Admin account deleted
- Or: DELETE /api/users/ADMIN_ID

Impact: Admin account deletion by regular users

Ref: hackerone.com/reports/206227, [medium.com/@edoverflow delete-admin](https://medium.com/@edoverflow/delete-admin)

P2 #93 Impersonate via OAuth Scope Manipulation

Target: OAuth implementations

Steps:

- OAuth authorize URL has: scope=read
- Change to: scope=admin, scope=impersonate
- User authorizes with elevated scope
- Attacker gets admin-level access token

Impact: Elevated OAuth scope grants without verification

Ref: hackerone.com/reports/296372, [medium.com/@fransrosen oauth-scope-escalation](https://medium.com/@fransrosen/oauth-scope-escalation)

P1 #94 Bypass KYC to Access Restricted Features

Target: Financial / Crypto platforms

Steps:

- Account requires KYC for trading
- Try trading endpoints without completing KYC
- Or: POST /api/kyc/verify with: status=verified, approved=true
- Trading enabled without actual KYC

Impact: Access financial features without identity verification

Ref: hackerone.com/reports/417614, medium.com/@vulnerability_kyc-bypass

P2 #95 Access Beta/Internal Features via Parameter

Target: SaaS platforms - Google, Twitter style

Steps:

- Check cookies and localStorage for feature flags
- Try: ?beta=true, ?internal=1, ?staff=1
- Or add header: X-Internal-Mode: true
- Internal/beta features unlocked

Impact: Unreleased internal features exposed

Ref: hackerone.com/reports/317931 (Twitter), medium.com/@stefanofinding_beta-feature-access

4. Payment & Pricing (Issues 96–120)

P1 #96 Purchase for \$0 via Price Parameter

Target: E-commerce – Generic

Steps:

- Add item (\$100) to cart
- Proceed to checkout
- Intercept checkout request
- Change: price=100 to price=0
- Order confirmed at \$0

Impact: Free purchase of any item

Ref: hackerone.com/reports/131480, medium.com/@busesz/zero-price-purchase

P1 #97 Negative Price Purchase (Get Refunded)

Target: E-commerce / Checkout flows

Steps:

- Add item to cart
- Intercept checkout
- Set: price=-100
- Complete checkout
- Account credited \$100 instead of charged

Impact: Store credits money into attacker account

Ref: hackerone.com/reports/531008, medium.com/@seanmelia/negative-price

P1 #98 Price Overflow to Zero

Target: E-commerce with integer pricing

Steps:

- Add expensive item (\$999) to cart
- Set price=2147483648 (2^{31})
- Integer overflow causes price to wrap to 0
- Item purchased for free

Impact: Integer overflow causes free purchase

Ref: hackerone.com/reports/423855, medium.com/@detectify/price-overflow

P2 #99 Coupon Code Reuse After Limit Reached

Target: E-commerce platforms

Steps:

- Single-use coupon applied to cart
- Checkout succeeds

- Create new account
- Apply same coupon again
- Coupon works despite single-use limit

Impact: Single-use coupons used multiple times

Ref: hackerone.com/reports/417714, [medium.com/@anshuman_bh coupon-reuse](https://medium.com/@anshuman_bh/coupon-reuse)

P1 #100 Stack Multiple Coupons Simultaneously

Target: E-commerce platforms

Steps:

- Add item to cart
- Apply coupon1: 50% off
- Apply coupon2: 50% off
- Both coupons applied
- Price becomes \$0 or negative

Impact: Free or negative total via coupon stacking

Ref: hackerone.com/reports/351344, [medium.com/@seanmelia coupon-stack](https://medium.com/@seanmelia/coupon-stack)

P2 #101 Apply Expired Coupon

Target: E-commerce platforms

Steps:

- Find expired coupon code
- Add item to cart
- Apply expired coupon at checkout
- Server accepts expired coupon without validation

Impact: Discounts via expired coupons

Ref: hackerone.com/reports/218900, [medium.com/@busesz expired-coupon](https://medium.com/@busesz/expired-coupon)

P2 #102 Apply Employee/Internal Coupon

Target: E-commerce platforms

Steps:

- Guess internal coupon: EMPLOYEE50, STAFF100, INTERNAL75
- Or find in JS source code, API responses
- Apply at checkout
- Internal discount applied

Impact: Internal/employee discounts leaked

Ref: hackerone.com/reports/264802, [medium.com/@intidec internal-coupon](https://medium.com/@intidec/internal-coupon)

P1 #103 Currency Arbitrage - Pay in Weak Currency

Target: Multi-currency platforms

Steps:

- Add item priced at \$100 USD

- Change currency to ARS (Argentine Peso)
- Price shows 85,000 ARS (about \$100)
- Pay with credit card in ARS
- Bank converts at real rate, item costs fraction of USD price

Impact: Pay significantly less via currency arbitrage

Ref: hackerone.com/reports/344070, medium.com/@seanmelia/currency-arbitrage

P1 #104 Currency Downgrade at Payment Gateway

Target: Payment processors - Stripe, PayPal style

Steps:

- Start checkout in USD
- Switch currency to JPY at last step
- Payment processed in JPY at lower effective rate
- Switch back to USD in confirmation

Impact: Pay less by switching currency at checkout

Ref: hackerone.com/reports/351344, medium.com/@anshuman_bh/currency-downgrade

P2 #105 Remove Item from Cart After Discount Applied

Target: E-commerce with promotions

Steps:

- Add qualifying item (\$50) + target item (\$100)
- Free shipping threshold (\$50) met
- Remove qualifying item from cart
- Free shipping discount remains
- \$100 item ships free

Impact: Free shipping/discount without qualifying purchase

Ref: hackerone.com/reports/312948, medium.com/@vulnerability/cart-remove-discount

P2 #106 Quantity Zero Gets Free Shipping

Target: E-commerce shipping calculations

Steps:

- Add expensive item (\$10)
- Add bulky item with \$50 shipping
- Set bulky item quantity to 0
- Shipping still calculated as \$50
- Free shipping threshold not recalculated

Impact: Incorrect shipping calculation on quantity change

Ref: hackerone.com/reports/264802, medium.com/@seanmelia/qty-zero-shipping

P1 #107 Race Condition: Double-Spend Balance

Target: Wallet / Balance-based platforms

Steps:

- Account balance: \$100
- Send two \$100 purchase requests simultaneously
- Both processed before balance updates
- Two orders confirmed, balance now -\$100

Impact: Double-spending from single balance

Ref: hackerone.com/reports/1186992, medium.com/@josipfranjic/race-double-spend

P2**#108 Fractional Quantity at Fractional Price**

Target: E-commerce quantity handling

Steps:

- Add item priced at \$10
- Set quantity to 0.1
- System calculates: \$1.00
- Purchase 0.1 quantity for \$1
- Or: quantity=0.5, price halves

Impact: Partial purchase at reduced price

Ref: hackerone.com/reports/286048, medium.com/@detectify/fractional-qty

P2**#109 Change Price After Adding to Cart**

Target: E-commerce with session carts

Steps:

- Add item at \$10 sale price
- Wait for sale to end, price back to \$20
- Proceed to checkout with old session
- Old sale price still honored

Impact: Stale pricing honored after sale ends

Ref: hackerone.com/reports/189234, medium.com/@busesz/stale-price-cart

P1**#110 Gift Card Balance Manipulation**

Target: Gift card / Wallet platforms

Steps:

- Purchase \$10 gift card
- Intercept gift card creation
- Change balance from 10 to 1000
- Gift card issued with \$1000 balance

Impact: Gift card with inflated balance

Ref: hackerone.com/reports/403050, medium.com/@bugbounty/gift-card-inflate

P2**#111 Subscription Trial Infinite Loop**

Target: SaaS trial platforms

Steps:

- Sign up for free trial
- Cancel before trial ends
- Sign up again with same email
- New trial granted
- Repeat indefinitely

Impact: Infinite free trials with same credentials

Ref: hackerone.com/reports/237166, medium.com/@anshuman_bh_infinite-trial

P1**#112 Upgrade Plan Without Paying - Client-Side Price**

Target: SaaS subscription platforms

Steps:

- Select premium plan (\$50/month)
- Intercept subscription request
- Change amount to 0.01
- Subscribe at \$0.01/month
- Premium features activated

Impact: Premium subscription at near-zero price

Ref: hackerone.com/reports/441163, medium.com/@seanmelia_plan-price-tamper

P1**#113 Partial Refund Abuse - Multiple Partial Refunds**

Target: E-commerce refund systems

Steps:

- Purchase item for \$100
- Request partial refund: \$10
- Refund processed, \$90 balance
- Request another \$10 partial refund
- Repeat until full refund achieved
- Item kept, full refund received

Impact: Full refund via multiple partial refunds

Ref: hackerone.com/reports/286048, medium.com/@detectify_partial-refund-abuse

P2**#114 Return Abuse - Return Different Item**

Target: E-commerce return systems

Steps:

- Purchase expensive item (\$500)
- Purchase cheap item (\$10)
- Return cheap item in expensive box
- System processes refund for expensive item
- Or: return broken/old version, keep new one

Impact: Refund fraud via item substitution

Ref: hackerone.com/reports/264802, medium.com/@vulnerability_return-substitution

P2 #115 Tax Jurisdiction Manipulation

Target: E-commerce with tax calculation

Steps:

- Set billing address to Delaware (no sales tax)
- Set shipping to your real address
- Tax calculated based on billing (0%)
- Save sales tax on purchase

Impact: Tax evasion via billing address manipulation

Ref: hackerone.com/reports/189234, medium.com/@seanmelia/tax-jurisdiction

P2 #116 Cash on Delivery Bypass for Digital Products

Target: Marketplaces with COD option

Steps:

- Add digital product to cart
- Select Cash on Delivery payment
- Order confirmed without payment
- Digital product delivered instantly

Impact: Digital products obtained without payment

Ref: hackerone.com/reports/218900, medium.com/@busesz/cod-digital-bypass

P1 #117 Payment Callback Spoofing

Target: Payment gateway integrations

Steps:

- Complete purchase, capture payment callback
- Note callback URL and parameters
- Forge callback: payment_status=success
- Send forged callback to merchant
- Order marked as paid without actual payment

Impact: Order confirmed without actual payment

Ref: hackerone.com/reports/380102, medium.com/@josipfranjic/callback-spoof

P1 #118 Authorization vs Capture Timing Abuse

Target: Credit card payment flows

Steps:

- Add items to cart, proceed to payment
- Card authorized but not captured
- Order confirmed
- Change/cancel order before capture
- Capture fails but goods already shipped

Impact: Goods shipped without successful payment capture

Ref: hackerone.com/reports/286048, medium.com/@detectify/auth-capture-race

P2

#119 VAT Number Abuse for Tax-Free

Target: EU/international commerce

Steps:

- Enter any valid EU VAT number at checkout
- System removes VAT without validating ownership
- Purchase goods VAT-free without being a business

Impact: VAT-free purchases without legitimate business status

Ref: hackerone.com/reports/286091, [medium.com/@seanmelia vat-number-abuse](https://medium.com/@seanmelia/vat-number-abuse)

P2

#120 Shipping Address to Low-Cost Country

Target: International shipping platforms

Steps:

- Set shipping address to low-cost shipping zone
- Place order
- Change address after order to real destination
- Order ships to expensive zone at cheap rate

Impact: Pay low shipping rate for high-cost destination

Ref: hackerone.com/reports/312948, [medium.com/@vulnerability shipping-zone-bypass](https://medium.com/@vulnerability/shipping-zone-bypass)

5. Account Takeover (Issues 121-145)

P1 #121 Password Reset Host Header Poisoning

Target: Generic – password reset flows

Steps:

- Request password reset for victim@target.com
- Intercept request, add: X-Forwarded-Host: attacker.com
- Victim receives email with attacker.com reset link
- Attacker captures reset token
- Visit /reset?token=TOKEN and set new password

Impact: Any account takeover via poisoned reset link

Ref: hackerone.com/reports/1169520 (Twitter), [medium.com/@fransrosen host-header-password-reset](https://medium.com/@fransrosen/host-header-password-reset)

P1 #122 Password Reset Token Leak in Response

Target: Generic – password reset

Steps:

- Request password reset
- Check JSON response body
- Look for reset_token, reset_url in response
- Token leaked in API response despite being sent via email

Impact: Reset token accessible without email access

Ref: hackerone.com/reports/1270782, [medium.com/@nahamsec reset-token-leak](https://medium.com/@nahamsec/reset-token-leak)

P1 #123 Email Change Without Verification to ATO

Target: Generic – account settings

Steps:

- Login to victim account (obtained via XSS/session)
- Change email to attacker@email.com
- No verification email sent
- Request password reset on new email
- Take over account completely

Impact: ATO via unverified email change

Ref: hackerone.com/reports/508439, [medium.com/@seanmelia email-change-ato](https://medium.com/@seanmelia/email-change-ato)

P1 #124 Account Takeover via Username/Email Collision

Target: Case-insensitive databases

Steps:

- Victim account: User@target.com
- Register: user@target.com (lowercase)

- System treats as different due to DB case sensitivity
- You control "different" account with same email

Impact: Account confusion leading to takeover

Ref: hackerone.com/reports/127982 (Slack), [medium.com/@busesz email-collision-ato](https://medium.com/@busesz/email-collision-ato)

P1 #125 Account Takeover via OAuth Pre-linking

Target: OAuth-enabled platforms

Steps:

- Victim has account with email: victim@target.com
- Attacker creates account via OAuth (Google) using victim@target.com
- System links OAuth to existing account
- Attacker can login as victim via OAuth

Impact: ATO via OAuth account linking

Ref: hackerone.com/reports/328637, [medium.com/@fransrosen oauth-prelinking-ato](https://medium.com/@fransrosen/oauth-prelinking-ato)

P1 #126 Account Takeover via Registration with Victim Email

Target: Registration without email verification

Steps:

- Register with victim@target.com
- No email verification required
- Account created and authenticated
- Request password reset
- Reset link sent to victim email (attacker now controls account)

Impact: ATO via registration without verification

Ref: hackerone.com/reports/273377, [medium.com/@akita_akito reg-no-verify-ato](https://medium.com/@akita_akito/reg-no-verify-ato)

P1 #127 Account Takeover via CSRF on Email Change

Target: Generic - email change

Steps:

- Victim is logged in
- Attacker crafts: POST /change-email {email: attacker@email.com}
- Victim visits attacker page with CSRF payload
- Email changed silently
- Attacker resets password via new email

Impact: Silent ATO via CSRF email change

Ref: hackerone.com/reports/508439, [medium.com/@seanmelia csrf-email-ato](https://medium.com/@seanmelia/csrf-email-ato)

P2 #128 Account Takeover via Password Reset to Old Email

Target: Generic - email history

Steps:

- User changed email from old@email.com to new@email.com

- Request password reset
- System still sends to old@email.com
- Attacker controls old email
- Takes over account

Impact: ATO via stale email on password reset

Ref: hackerone.com/reports/286091, medium.com/@vulnerability-stale-email-reset

P2 #129 Account Takeover via Brute Force Password

Target: Weak password policy platforms

Steps:

- Identify victim username/email
- Try common passwords: Password123, Welcome1, Summer2024
- Use Burp Intruder with weak password list
- No account lockout after failed attempts
- Correct password found

Impact: ATO via credential stuffing/brute force

Ref: hackerone.com/reports/170831, [medium.com/@nahamsec password-brute-ato](https://medium.com/@nahamsec/password-brute-ato)

P2 #130 Account Takeover via Session Hijacking (No Binding)

Target: Generic - session management

Steps:

- Steal session token via XSS/MITM
- Use session token from different IP/browser
- Session not bound to IP/User-Agent
- Login successful as victim

Impact: Session usable from any location/device

Ref: hackerone.com/reports/489146, [medium.com/@vijayknown session-hijack-ato](https://medium.com/@vijayknown/session-hijack-ato)

P1 #131 Account Takeover via Phone Number Change

Target: Phone-based 2FA platforms

Steps:

- Login to compromised victim session
- Change phone number to attacker number
- No SMS verification on change
- Request 2FA code, sent to attacker
- Complete login takeover

Impact: 2FA hijacked via phone number change

Ref: hackerone.com/reports/273377, [medium.com/@akita_akito phone-change-ato](https://medium.com/@akita_akito/phone-change-ato)

P2 #132 Account Takeover via Security Question Bypass

Target: Generic - security questions

Steps:

- Start password reset flow
- Select "Answer security question"
- Try common answers: "dog", "mother", "school"
- Brute force answers
- Or: answer validation done client-side

Impact: Reset password via guessed security answers

Ref: hackerone.com/reports/195286, [medium.com/@knownsec security-question-ato](https://medium.com/@knownsec/security-question-ato)

P1

#133 Account Takeover via IDOR on Password Change

Target: Generic - password change API

Steps:

- Login as User A (attacker)
- POST /api/change-password with: user_id=VICTIM_ID
- Server changes victim password instead of yours
- Login as victim with new password

Impact: Change any users password via IDOR

Ref: hackerone.com/reports/231981, [medium.com/@edoverflow idor-password-change](https://medium.com/@edoverflow/idor-password-change)

P1

#134 Account Takeover via JWT JKU Header

Target: JWT-based authentication

Steps:

- Decode JWT, note jku header
- Create attacker JWKS at <https://attacker.com/jwks.json>
- Set jku to attacker URL
- Sign forged token with attacker private key
- Server fetches key from attacker URL

Impact: Forge tokens for any user via JKU injection

Ref: hackerone.com/reports/214580, [medium.com/@vavkamil jku-ato](https://medium.com/@vavkamil/jku-ato)

P1

#135 Account Takeover via IDOR on Email Update

Target: Generic - profile update

Steps:

- Login as User A
- POST /api/update-email with: user_id=VICTIM_ID, email=attacker@email.com
- Victims email updated to attacker email
- Reset password, take over account

Impact: Change victim email via IDOR then reset password

Ref: hackerone.com/reports/508439, [medium.com/@seanmelia idor-email-update](https://medium.com/@seanmelia/idor-email-update)

P1

#136 Account Takeover via Subdomain Takeover Chain

Target: Generic – subdomain-based services

Steps:

- Find expired subdomain: profile.target.com CNAME to heroku
- Claim subdomain on Heroku
- Victim password reset sent to profile.target.com
- Capture reset token on attacker server

Impact: ATO via subdomain takeover capturing reset emails

Ref: hackerone.com/reports/328637, [medium.com/@fransrosen subdomain-takeover-ato](https://medium.com/@fransrosen/subdomain-takeover-ato)

P1

#137 Account Takeover via Unicode Normalization

Target: Unicode-supporting platforms

Steps:

- Victim: admin@target.com
- Register: admin@target.coma (with Cyrillic a)
- System normalizes to different value
- Attacker receives emails meant for admin

Impact: ATO via homograph email attack

Ref: hackerone.com/reports/562335 (Slack), [medium.com/@busesz unicode-normalization-ato](https://medium.com/@busesz/unicode-normalization-ato)

P1

#138 Account Takeover via Response Manipulation on Login

Target: Client-side auth checks

Steps:

- Login with valid credentials
- Intercept response: {"auth": false, "2fa_required": true}
- Change to: {"auth": true, "2fa_required": false}
- Bypass 2FA and login complete

Impact: Login/2FA bypass via response manipulation

Ref: hackerone.com/reports/149165, [medium.com/@akita_akito response-auth-ato](https://medium.com/@akita_akito/response-auth-ato)

P1

#139 Account Takeover via SSRF on Internal Reset Endpoint

Target: Internal network access

Steps:

- Find SSRF vulnerability
- Use SSRF to hit: http://localhost:8080/internal/reset
- Internal reset endpoint lacks auth
- Trigger reset for any user from internal network

Impact: ATO via SSRF to internal reset endpoints

Ref: hackerone.com/reports/231549, [medium.com/@nahamsec ssrf-internal-reset](https://medium.com/@nahamsec/ssrf-internal-reset)

P2

#140 Account Takeover via Backup Code Brute Force

Target: 2FA with backup codes

Steps:

- Login with credentials
- Select "Use backup code"
- Enter 8-char code: AAAAAAAA
- Send to Burp Intruder
- Brute force with alphanumeric list

Impact: 2FA bypass via backup code brute force

Ref: hackerone.com/reports/1166056, [medium.com/@nahamsec backup-brute-ato](https://medium.com/@nahamsec/backup-brute-ato)

P1**#141 Account Takeover via OAuth Redirect URI Manipulation**

Target: OAuth implementations

Steps:

- OAuth flow: /oauth/authorize?redirect_uri=https://app.target.com/callback
- Change to: redirect_uri=https://attacker.com/callback
- If not validated, code sent to attacker
- Exchange code for access token

Impact: OAuth code interception via redirect manipulation

Ref: hackerone.com/reports/107702 (Facebook), [medium.com/@fransrosen oauth-redirect-ato](https://medium.com/@fransrosen/oauth-redirect-ato)

P1**#142 Account Takeover via SAML Response Manipulation**

Target: SAML SSO implementations

Steps:

- Intercept SAML response
- Modify NameID to victim@target.com
- Re-sign or strip signature
- Send modified response
- Logged in as victim

Impact: SAML authentication bypass to impersonate victim

Ref: hackerone.com/reports/107702, [medium.com/@vavkamil saml-ato](https://medium.com/@vavkamil/saml-ato)

P2**#143 Account Takeover via Password Reset Without Current Password**

Target: Generic - settings

Steps:

- Login to account
- Go to change password
- Enter new password without old password
- Server accepts without current password verification

Impact: Password changed without current password

Ref: hackerone.com/reports/201800, [medium.com/@akita_akito no-old-password](https://medium.com/@akita_akito/no-old-password)

P2**#144 Account Takeover via Trust This Device Bypass**

Target: Generic - 2FA remember device

Steps:

- Login with credentials
- At 2FA prompt, check "Trust this device"
- Add parameter: trust_device=true, remember=true
- Skip 2FA verification entirely

Impact: 2FA bypass via trust device parameter

Ref: hackerone.com/reports/149165, [medium.com/@akita_akito trust-device-bypass](https://medium.com/@akita_akito/trust-device-bypass)

P1

#145 Account Takeover via Deactivate/Reactivate Account

Target: Generic - account management

Steps:

- Victim has 2FA enabled
- Attacker gains session via XSS
- Deactivate victim account
- Reactivate account
- 2FA sometimes disabled on reactivation
- Account now accessible without 2FA

Impact: 2FA removed via deactivate/reactivate cycle

Ref: hackerone.com/reports/347282, [medium.com/@seanmelia deactivate-2fa-bypass](https://medium.com/@seanmelia/deactivate-2fa-bypass)

6. Race Conditions (Issues 146–155)

P1 #146 Race Condition: Double Withdrawal

Target: Banking/Wallet platforms

Steps:

- Account balance: \$100
- Send two withdrawal requests of \$100 simultaneously
- Use Burp Repeater or Turbo Intruder
- Both withdrawals processed before balance update
- Balance: -\$100, two \$100 transactions confirmed

Impact: Double-spending from single balance

Ref: hackerone.com/reports/1186992, medium.com/@josipfranjic/race-double-withdrawal

P1 #147 Race Condition: Multiple Coupon Redemption

Target: E-commerce platforms

Steps:

- Single-use coupon for \$50 off
- Add item to cart, apply coupon
- Send checkout request 10 times simultaneously
- All 10 requests process before coupon marked used
- 10 orders confirmed with \$50 off each

Impact: Single-use coupon applied multiple times

Ref: hackerone.com/reports/351344, medium.com/@seanmelia/race-coupon

P2 #148 Race Condition: Vote Manipulation

Target: Voting/Polling platforms – Twitter polls style

Steps:

- One vote per user limit
- Send 100 vote requests simultaneously
- All counted before vote check
- Vote count inflated by 100x

Impact: Inflated vote counts in polls

Ref: hackerone.com/reports/189234, medium.com/@busesz/race-voting

P1 #149 Race Condition: Inventory Oversell

Target: E-commerce limited stock

Steps:

- Limited item: 1 in stock
- 50 users add to cart simultaneously

- All 50 checkouts process before inventory updates
- 50 orders confirmed for 1 item

Impact: Sell more inventory than available

Ref: hackerone.com/reports/286048, [medium.com/@detectify race-inventory](https://medium.com/@detectify/race-inventory)

P1 #150 Race Condition: Referral Bonus Multiplication

Target: Referral systems

Steps:

- Referral bonus: \$10 per invitee
- Send 50 invite acceptance requests simultaneously
- All processed before referral counter updates
- \$500 credited for 1 invitee

Impact: Referral credits multiplied

Ref: hackerone.com/reports/286048, [medium.com/@detectify race-referral](https://medium.com/@detectify/race-referral)

P2 #151 Race Condition: Follower/Subscriber Inflation

Target: Social platforms – Twitter, YouTube style

Steps:

- One follow per user
- Send 100 follow requests for same user simultaneously
- All processed before follow check
- User gains 100 followers from 1 account

Impact: Inflated follower counts

Ref: hackerone.com/reports/237166, [medium.com/@anshuman_bh race-follower](https://medium.com/@anshuman_bh/race-follower)

P1 #152 Race Condition: Duplicate Transfer

Target: Payment/Transfer platforms

Steps:

- Account balance: \$1000
- Send two transfer requests of \$1000 simultaneously
- Both processed, \$2000 transferred from \$1000 balance
- Account goes negative

Impact: Duplicate transfers exceeding balance

Ref: hackerone.com/reports/1186992, [medium.com/@josipfranjic race-transfer](https://medium.com/@josipfranjic/race-transfer)

P2 #153 Race Condition: Like/Upvote Manipulation

Target: Social platforms – Reddit, Medium style

Steps:

- One like per user
- Send 50 like requests simultaneously
- All counted before like validation

- Post receives 50 likes from 1 user

Impact: Inflated engagement metrics

Ref: hackerone.com/reports/189234, medium.com/@busesz/race-like

P2

#154 Race Condition: API Rate Limit Bypass

Target: API platforms

Steps:

- Rate limit: 100 requests/minute
- Send 500 requests in first second
- All processed before rate counter updates
- API abused beyond limits

Impact: Bypass API rate limiting

Ref: hackerone.com/reports/1176994, medium.com/@nahamsec/race-ratelimit

P1

#155 Race Condition: Sign-Up Bonus Multiple Credit

Target: Reward platforms

Steps:

- Welcome bonus: \$5 per new account
- Send 20 account creation requests simultaneously with same email
- Multiple accounts created before uniqueness check
- Multiple \$5 bonuses credited

Impact: Multiple welcome bonuses from single signup

Ref: hackerone.com/reports/237166, medium.com/@anshuman_bh/race-signup-bonus

7. Business Logic Bypass (Issues 156–180)

P1 #156 KYC Verification Bypass via Parameter Tampering

Target: Financial/Crypto platforms

Steps:

- Account requires KYC for trading
- POST /api/kyc/submit with: status=pending
- Intercept response, change to: verified=true
- Or: POST /api/account with: kyc_verified=true, kyc_status=approved
- Trading enabled without KYC

Impact: Access financial features without identity verification

Ref: hackerone.com/reports/417614, [medium.com/@vulnerability kyc-bypass-logic](https://medium.com/@vulnerability/kyc-bypass-logic)

P1 #157 Workflow Bypass – Skip Payment Step

Target: E-commerce checkout flows

Steps:

- Normal flow: Cart -> Shipping -> Payment -> Confirmation
- POST directly to /checkout/confirm
- Or: skip_step=payment, step=confirmation
- Order confirmed without payment processing

Impact: Complete checkout without paying

Ref: hackerone.com/reports/131480, [medium.com/@busesz skip-payment](https://medium.com/@busesz/skip-payment)

P1 #158 Workflow Bypass – Skip OTP Verification

Target: Banking/Transfer flows

Steps:

- Normal: Transfer -> OTP -> Confirm
- POST directly to /transfer/confirm
- Add: otp_verified=true, verified=true
- Transfer confirmed without OTP

Impact: High-value transfers without OTP verification

Ref: hackerone.com/reports/330258, [medium.com/@fransrosen skip-otp](https://medium.com/@fransrosen/skip-otp)

P2 #159 Workflow Bypass – Skip Email Verification

Target: Registration flows

Steps:

- Register account
- Normal: verify email before access
- POST /api/account/activate with: verified=true

- Or access protected endpoints without verification

Impact: Account access without email verification

Ref: hackerone.com/reports/273377, medium.com/@akita_akito/skip-email-verify

P2 #160 Workflow Bypass – Skip Approval for Sensitive Action

Target: Enterprise – admin approval

Steps:

- Normal: Request → Manager Approval → Execute
- POST directly to /execute with: approved=true, approval_id=fake
- Action executed without approval

Impact: Sensitive actions without required approval

Ref: hackerone.com/reports/231549, medium.com/@bugbounty/skip-approval

P2 #161 Account Deletion Bypass – Cancel After Trigger

Target: Generic – account deletion

Steps:

- Request account deletion
- Deletion scheduled in 30 days
- During grace period, cancel deletion via API
- Account restored with all data
- Repeat to keep account indefinitely after deletion request

Impact: Account data retention despite deletion request

Ref: hackerone.com/reports/347282, medium.com/@seanmelia/deletion-cancel-bypass

P2 #162 Age Verification Bypass via Parameter

Target: Age-restricted platforms

Steps:

- Access age-restricted content
- Prompt asks for age verification
- Add: age_verified=true, over_18=true
- Or: birth_date=1990-01-01
- Access granted without verification

Impact: Age-restricted content accessible to minors

Ref: hackerone.com/reports/286048, medium.com/@detectify/age-bypass

P2 #163 Geographic Restriction Bypass via VPN Header

Target: Geo-blocked content

Steps:

- Content blocked for your region
- Add: X-Forwarded-For: US_IP_ADDRESS
- Or: CF-IPCountry: US, X-Country-Code: US

- Content region check bypassed

Impact: Access geo-restricted content

Ref: hackerone.com/reports/286091, medium.com/@seanmelia/geo-bypass

P2 #164 Download Limit Bypass via Cookie Reset

Target: File download platforms

Steps:

- Download limit: 5 per day
- Download 5 files
- Clear cookies or use incognito
- Download 5 more files
- Or: increment download counter cookie

Impact: Download unlimited files despite limits

Ref: hackerone.com/reports/264802, medium.com/@vulnerability/download-limit-bypass

P2 #165 Content Limit Bypass via Pagination Abuse

Target: Search/Content platforms - LinkedIn Premium style

Steps:

- Free tier: view 10 results
- Search returns 10 results
- Add: offset=10, page=2
- View results 11-20 without subscription
- Continue paginating

Impact: Access premium content via pagination

Ref: hackerone.com/reports/264802, medium.com/@intidec/pagination-bypass

P2 #166 Verification Badge Bypass via Parameter

Target: Social platforms - Twitter Verified style

Steps:

- Account shows verification badge
- POST `/api/profile` with: `verified=true, blue_verified=true`
- Profile displays verification badge
- Or: `is_verified=1, badge=verified`

Impact: Fake verification badge on account

Ref: hackerone.com/reports/1008026 (Twitter), medium.com/@rajstarcx/verified-badge-bypass

P1 #167 Account Suspension Bypass via New Endpoint

Target: Generic - suspended accounts

Steps:

- Account suspended, cannot login
- Try alternative login: `/api/v2/login` instead of `/v1`

- Or: /mobile/login, /internal/login
- Alternative endpoint does not check suspension

Impact: Suspended accounts can still access platform

Ref: hackerone.com/reports/322985 (Twitter), [medium.com/@beergut1 suspension-bypass](https://medium.com/@beergut1/suspension-bypass)

P2 #168 Rate Limit Bypass via IP Rotation Headers

Target: Generic - rate-limited endpoints

Steps:

- Rate limited after 100 requests
- Add: X-Forwarded-For: random_ip
- Or: X-Real-IP: different_ip
- Each request appears from different IP
- Rate limit bypassed

Impact: Bypass rate limiting via IP spoofing

Ref: hackerone.com/reports/1176994, [medium.com/@nahamsec rate-limit-bypass](https://medium.com/@nahamsec/rate-limit-bypass)

P2 #169 Block/Mute Bypass via API Direct Access

Target: Social platforms - Twitter block style

Steps:

- User A blocks User B
- User B tries to view profile (blocked)
- User B calls /api/v2/user/profile directly
- Or uses GraphQL query
- Profile data accessible despite block

Impact: Block/mute bypassed via direct API access

Ref: hackerone.com/reports/487954 (Twitter), [medium.com/@nahamsec block-bypass](https://medium.com/@nahamsec/block-bypass)

P2 #170 Private Account Content Leak via Public API

Target: Social platforms - Instagram private style

Steps:

- Account set to private
- Public endpoints return: profile private
- Try /api/internal/posts?user_id=X
- Or /api/v1/feed/private_user
- Private posts accessible via alternative endpoint

Impact: Private content accessible via public API

Ref: hackerone.com/reports/1158696, [medium.com/@detailyogi private-content-leak](https://medium.com/@detailyogi/private-content-leak)

P2 #171 Quiz/Test Answer Bypass via Client-Side Validation

Target: Education platforms

Steps:

- Take online quiz
- Client-side JavaScript validates answers
- Modify JS or intercept responses
- All answers marked correct
- Or: correct answers visible in page source

Impact: Quiz answers revealed or bypassed

Ref: hackerone.com/reports/264802, medium.com/@vulnerability/quiz-bypass

P2 #172 Captcha Bypass via Direct API Call

Target: Generic – captcha-protected forms

Steps:

- Form requires captcha
- Solve captcha, note validation token
- Reuse same token for multiple submissions
- Or: POST directly to `/api/submit` bypassing captcha validation
- Captcha validation skipped

Impact: Spam/bot submissions via captcha bypass

Ref: hackerone.com/reports/286048, medium.com/@detectify/captcha-bypass

P2 #173 Invitation-Only Signup Bypass via Parameter

Target: Beta/Exclusive platforms

Steps:

- Registration requires invite code
- POST `/register` with: `invite_code=test`, `invite=skip`
- Or: `beta_access=true`, `bypass_invite=1`
- Registration completes without valid invite

Impact: Access invitation-only platforms

Ref: hackerone.com/reports/237166, medium.com/@anshuman_bh/invite-bypass

P2 #174 Character Limit Bypass via Direct API

Target: Platforms with content limits – Twitter style

Steps:

- Frontend limits: 280 characters
- Post via `/api/v2/tweet` with body: 5000 characters
- Backend does not enforce limit
- Long content accepted despite UI restriction

Impact: Bypass content length restrictions

Ref: hackerone.com/reports/487954 (Twitter), medium.com/@nahamsec/char-limit-bypass

P2 #175 File Upload Type Restriction Bypass

Target: File upload platforms

Steps:

- Only images allowed (.jpg, .png)
- Upload .php file
- Rename: shell.jpg.php
- Or: Content-Type: image/jpeg with .php body
- Server accepts based on Content-Type not extension

Impact: Upload executable files via type confusion

Ref: hackerone.com/reports/269209 (LinkedIn), [medium.com/@anshuman_bh file-type-bypass](https://medium.com/@anshuman_bh/file-type-bypass)

P2

#176 Time-Based Restriction Bypass (After Hours)

Target: Enterprise – time-limited features

Steps:

- Feature only available 9 AM – 5 PM
- Change system time on device
- Or: X-Client-Time: 12:00 (during off-hours)
- Feature accessible outside allowed hours

Impact: Access time-restricted features anytime

Ref: hackerone.com/reports/286091, [medium.com/@seanmelia time-restriction-bypass](https://medium.com/@seanmelia/time-restriction-bypass)

P2

#177 Content Moderation Bypass via Encoding

Target: Social platforms – profanity filters

Steps:

- Submit content with banned words
- Encode: bad instead of bad
- Or: b.a.d, b_a_d, bad (Cyrillic a)
- Filter does not catch encoded variants
- Content accepted

Impact: Bypass content moderation/filters

Ref: hackerone.com/reports/195286, [medium.com/@knownsec filter-bypass-encoding](https://medium.com/@knownsec/filter-bypass-encoding)

P2

#178 Password Complexity Bypass via Direct API

Target: Generic – password policies

Steps:

- UI requires: 8 chars, uppercase, number, symbol
- POST /api/change-password with: password=abc
- Backend does not enforce complexity
- Weak password accepted

Impact: Set weak passwords bypassing complexity rules

Ref: hackerone.com/reports/286048, [medium.com/@detectify password-complexity-bypass](https://medium.com/@detectify/password-complexity-bypass)

P2

#179 Domain Blocklist Bypass via Subdomain

Target: Platforms with URL restrictions

Steps:

- Blocked: evil.com
- Try: evil.com.good.com
- Or: good.com.evil.com
- Or: evil.co (different TLD)
- URL parser does not catch subdomain trick
- Malicious URL accepted

Impact: Share malicious URLs despite blocklist

Ref: hackerone.com/reports/487954 (Twitter), medium.com/@nahamsec/blocklist-bypass

P2

#180 Device Limit Bypass via User-Agent Spoofing

Target: Streaming platforms - Netflix style

Steps:

- Limited to 2 devices
- Login on 3rd device blocked
- Change User-Agent to match existing device
- Or: device_id=existing_device_id
- 3rd device login accepted

Impact: Stream on more devices than allowed

Ref: hackerone.com/reports/286048, medium.com/@detectify/device-limit-bypass

8. API Logic & Feature Abuse (Issues 181–200)

P2 #181 GraphQL Introspection Enabled – Full Schema Leak

Target: GraphQL APIs

Steps:

- POST to /graphql with: query { __schema { types { name fields { name } } } }
- Full schema returned
- Enumerate all queries, mutations, subscriptions
- Find admin operations and hidden fields

Impact: Complete API schema exposed including admin operations

Ref: hackerone.com/reports/745903, medium.com/@graphql-hacker/introspection-schema

P1 #182 GraphQL Alias for Batch IDOR

Target: GraphQL APIs – GitHub style

Steps:

- Normal query: query { user(id: "1") { email } }
- Use aliases: query { a1: user(id: "1") { email } a2: user(id: "2") { email } ... a50: user(id: "50") { email } }
- 50 user emails in single request

Impact: Batch data extraction via GraphQL aliases

Ref: hackerone.com/reports/745903, medium.com/@graphql-hacker/graphql-alias-idor

P1 #183 GraphQL Mutation Without Auth

Target: GraphQL APIs

Steps:

- Introspect schema, find admin mutations
- Execute: mutation { deleteUser(id: "1") { success } }
- No authorization check on mutation
- Admin action succeeds as regular user

Impact: Admin mutations accessible without authorization

Ref: hackerone.com/reports/745903, medium.com/@graphql-hacker/graphql-mutation-auth

P2 #184 GraphQL Depth Limit Bypass

Target: GraphQL APIs

Steps:

- Query limited to depth 5
- Use fragments to nest deeper
- Or: use aliases to repeat nested queries
- Server does not count alias depth
- Excessive nesting achieved

Impact: Deep queries causing DoS or data exposure

Ref: hackerone.com/reports/745903, [medium.com/@graphql-hacker graphql-depth-bypass](https://medium.com/@graphql-hacker/graphql-depth-bypass)

P1 #185 Mass Assignment via Extra JSON Fields

Target: REST APIs – Rails/Node style

Steps:

- POST /api/users with: {email: "test@test.com", password: "pass"}
- Add: {..., is_admin: true, role: "admin", verified: true}
- Server saves all fields without filtering
- Admin account created

Impact: Privilege escalation via unfiltered parameter assignment

Ref: hackerone.com/reports/687907, [medium.com/@sakurity mass-assignment-rest](https://medium.com/@sakurity/mass-assignment-rest)

P2 #186 API Version Bypass – Old Version Lacks Security

Target: Multi-version APIs – Twitter API style

Steps:

- POST /v2/admin/delete requires admin role (403)
- Try: POST /v1/admin/delete
- Returns 200, no auth check in v1
- Admin action via legacy API

Impact: Legacy API endpoints lack security controls

Ref: hackerone.com/reports/769105 (Shopify), [medium.com/@anshuman_bh api-version-bypass](https://medium.com/@anshuman_bh/api-version-bypass)

P2 #187 Parameter Pollution – Duplicate Parameters

Target: Generic – REST APIs

Steps:

- GET /api/user?id=1 (shows your data)
- Try: GET /api/user?id=1&id=2
- Backend uses second parameter (id=2)
- Access user 2 data
- Or: first parameter depending on framework

Impact: Access control bypass via duplicate parameters

Ref: hackerone.com/reports/226293, [medium.com/@edoverflow parameter-pollution](https://medium.com/@edoverflow/parameter-pollution)

P2 #188 HTTP Method Override for Delete

Target: REST APIs with method restrictions

Steps:

- DELETE /api/post/1 blocked (method not allowed)
- POST /api/post/1 with: X-HTTP-Method-Override: DELETE
- Server processes as DELETE
- Post deleted

Impact: Bypass method restrictions via override header

Ref: hackerone.com/reports/209283, [medium.com/@thevillagehacker method-override](https://medium.com/@thevillagehacker/method-override)

P2 #189 CORS Misconfiguration for API Access

Target: Generic – APIs

Steps:

- Check API response headers
- Access-Control-Allow-Origin: * (wildcards)
- Or: Access-Control-Allow-Credentials: true with reflected origin
- Any website can make authenticated API calls

Impact: Cross-origin API access from malicious websites

Ref: hackerone.com/reports/317931 (Twitter), [medium.com/@stefanofinding cors-api-misconfig](https://medium.com/@stefanofinding/cors-api-misconfig)

P2 #190 Include Parameter for Sensitive Field Exposure

Target: REST APIs with relationships

Steps:

- GET /api/users/1?include=posts
- Try: ?include=password, ?include=credit_card
- Or: ?include=* for all relationships
- Sensitive related fields returned

Impact: Sensitive fields exposed via include parameter

Ref: hackerone.com/reports/508439, [medium.com/@seanmelia include-parameter](https://medium.com/@seanmelia/include-parameter)

P2 #191 Sort Parameter for Data Extraction

Target: REST APIs with sorting

Steps:

- GET /api/users?sort=created_at
- Try: ?sort=password, ?sort=credit_card, ?sort=ssn
- Or: ?sort=email to enumerate users by email
- Database sorts by sensitive field, leaks via timing or error

Impact: Data extraction via sort parameter on sensitive fields

Ref: hackerone.com/reports/286048, [medium.com/@detectify sort-extraction](https://medium.com/@detectify/sort-extraction)

P2 #192 Page Size Abuse for Mass Data Extraction

Target: Paginated APIs

Steps:

- GET /api/users?per_page=10
- Change to: ?per_page=999999 or ?limit=0
- Server returns all records
- Complete database dump in single request

Impact: Full dataset extraction via pagination abuse

Ref: hackerone.com/reports/508439, [medium.com/@seanmelia pagination-abuse](https://medium.com/@seanmelia/pagination-abuse)

P2 #193 Email Bombing via Registration

Target: Generic - registration flows

Steps:

- POST /register with: email=victim@target.com
- No rate limiting on registration
- Script 1000 registration requests
- Victim receives 1000 verification emails

Impact: Email bombing / notification spam

Ref: hackerone.com/reports/195286, [medium.com/@knownsec email-bombing](https://medium.com/@knownsec/email-bombing)

P2 #194 SMS Bombing via Phone Verification

Target: Phone verification flows

Steps:

- POST /verify-phone with: phone=victim_phone
- No rate limiting on SMS
- Script 500 verification requests
- Victim receives 500 SMS messages

Impact: SMS flooding to victim phone

Ref: hackerone.com/reports/286048, [medium.com/@detectify sms-bombing](https://medium.com/@detectify/sms-bombing)

P2 #195 Self-XSS Stored via Profile Field to Affect Admin

Target: Admin dashboard platforms

Steps:

- Set profile name to:
- Admin views user list
- XSS executes in admin context
- Steal admin session

Impact: Admin account takeover via stored XSS in user data

Ref: hackerone.com/reports/269209, [medium.com/@anshuman_bh self-xss-admin](https://medium.com/@anshuman_bh/self-xss-admin)

P1 #196 Webhook SSRF to Internal Services

Target: Webhook configuration platforms

Steps:

- Configure webhook URL: <http://169.254.169.254/latest/meta-data/>
- Trigger webhook event
- Server makes request to internal metadata
- Cloud credentials returned
- Or: <http://localhost:8080/admin/>

Impact: SSRF via webhook to access internal services

Ref: hackerone.com/reports/330258, [medium.com/@fransrosen webhook-ssrf](https://medium.com/@fransrosen/webhook-ssrf)

P1 #197 Export Function Abuse for Mass PII

Target: Data export platforms

Steps:

- Export your data: `/api/export?user_id=1`
- Change: `user_id=*` or `user_id=ALL`
- Or: `organization_id=1` to export all org data
- Mass PII export of all users

Impact: Mass PII extraction via export abuse

Ref: hackerone.com/reports/242831 (Twitter), medium.com/@hacker_export-mass-pii

P1 #198 Search Wildcard for Full Database Enumeration

Target: Search APIs

Steps:

- GET `/api/search?q=test`
- Try: `q=*` or `q=%`
- Or: `q=" OR 1=1--`
- Server returns all records
- Full database dump via search

Impact: Complete database enumeration via search

Ref: hackerone.com/reports/508439, [medium.com/@seanmelia search-wildcard](https://medium.com/@seanmelia/search-wildcard)

P2 #199 Feature Flag Discovery via API

Target: SaaS platforms - Google style

Steps:

- GET `/api/config` or `/api/feature-flags`
- Returns all feature flags and their values
- Find: `admin_dashboard: true, internal_tools: true`
- Access features via URL or parameter

Impact: Internal features exposed via config API

Ref: hackerone.com/reports/317931 (Twitter), [medium.com/@stefanofinding feature-flag-api](https://medium.com/@stefanofinding/feature-flag-api)

P2 #200 Recurring Billing Cancellation Timing Abuse

Target: Subscription platforms

Steps:

- Subscribe to monthly plan
- Use service for 29 days
- Cancel subscription on day 29
- Get full refund for month
- Or: cancel after billing, re-subscribe, get refund for old period

- Free service via timing manipulation

Impact: Free premium service via billing timing abuse

Ref: hackerone.com/reports/286048, [medium.com/@detectify billing-timing-abuse](https://medium.com/@detectify/billing-timing-abuse)